

ACG V3 — AGENT SECURITY INFRASTRUCTURE

Architectural Specification & Verification Evidence

Executive Summary

ACG V3 evolves the Control Plane into a hardened, observable, risk-aware **Enterprise Agent Security Infrastructure Layer**. Built directly on the V2 Control Plane foundations, V3 introduces:

1. Pluggable Risk Provider abstraction (RiskProvider / LocalHeuristicRiskProvider / Razorpay Vulcan Advisory).
2. Structured Decision Tracing (DecisionTraceRecorder) capturing granular phase latencies with automatic secret redaction.
3. Enterprise Agent Incident Console and Incident Response workflows (IncidentConsoleEngine).
4. Property-Based Security Invariant guarantees with randomized action sequence verification.
5. Fail-Closed Chaos & Failure Resilience.

V3 Subsystems & Security Architecture

```
[ INCOMING INTENT ]
|
▼
+████████████████████████████████████████████████████████████████████████████████+
| V3.2 Decision Trace Start | (trc_uuid)
+████████████████████████████████████████████████████████████████████████████████+
|
|
▼
+████████████████████████████████████████████████████████████████████████████████+
| V2 Authorization Pipeline | (Kill Switch -> Identity -> Capability -> Policy)
+████████████████████████████████████████████████████████████████████████████████+
| PASS
|
▼
+████████████████████████████████████████████████████████████████████████████████+
| V3.1 Advisory Risk Evaluation | (LocalHeuristicRiskProvider)
| (Basket size / category check) |
+████████████████████████████████████████████████████████████████████████████████+
| ADVISORY INPUT
|
▼
+████████████████████████████████████████████████████████████████████████████████+
| Policy Decision Point |
+████████████████████████████████████████████████████████████████████████████████+
|
|
+████████████████████████████████████████████████████████████████████████████████+
| |
| [ ALLOW ] [ ANOMALY / BREACH ]
| |
|
▼ ▼
+████████████████████████████████████████████████████████████████████████████████+
| Atomic Reservation | | V3.3/3.4 Incident |
| & Razorpay Settlement | | Console Logging & Ops |
+████████████████████████████████████████████████████████████████████████████████+
| (SUSPEND/REVOKE) |
| +████████████████████████████████████████████████████████████████████████████████+
|
▼
+████████████████████████████████████████████████████████████████████████████████+
| V3.2 Decision Trace |
| Finalized (Zero Redac)|
+████████████████████████████████████████████████████████████████████████████████+
```

V3 Detailed Specifications

1. Risk Provider Abstraction (V3.1)

- RiskProvider Interface:
- `evaluate(input: RiskEvaluationInput): Promise<RiskEvaluationResult>`
- Properties: `riskScore`, `riskTier`, `recommendedAction`, `signals`, `advisoryOnly: true`.
- Local Heuristic Provider: Computes basket size anomaly scores, high-risk category detection (`gift_cards`, `crypto_assets`), and transaction velocity flags.
- **Critical Security Invariant:** Risk providers are strictly advisory inputs to the Policy Decision Point and can never silently authorize or bypass merchant authorization policies.

2. Granular Decision Traces & Observability (V3.2 & V3.5)

- Endpoints:
- GET `/v1/traces/:traceId`
- GET `/v1/traces/intent/:intentId`
- Captures: Step latencies across `SCHEMA_VALIDATION`, `KILL_SWITCH`, `MANDATE_VERIFICATION`, `COMMERCE_TRUTH`, `POLICY_EVALUATION`, `RISK_EVALUATION`, `DUAL_RESERVATION`, and `RAILS_EXECUTION`.
- Redaction Engine: Automatically scrubs sensitive keys, tokens, bearer secrets, and authentication parameters before persistence.

3. Agent Incident Console & Response Workflows (V3.3 & V3.4)

- Incident Classification: `POLICY_VIOLATION`, `VELOCITY_ALERT`, `HIGH_RISK_DETECTED`, `SIGNATURE_TAMPER`, `MANDATE_EXHAUSTED`, `KILL_SWITCH_TRIGGER`.
- Operational Actions:
- `SUSPEND_AGENT`: Dynamically places agent in `SUSPENDED` state, blocking all new checkouts.
- `REVOKE_AGENT`: Permanently revokes agent principal.
- `REVOKE_MANDATE`: Marks mandate revoked in the cryptographic control plane registry.
- `PAUSE_MERCHANT_AGENTS`: Triggers merchant-scoped kill switch.
- `CLEAR_AFTER_REVIEW`: Resolves incident upon SecOps review.

4. Property-Based Security Invariants (V3.6)

- Evaluated under randomized sequential and concurrent loads:
- 1. `available_stock >= 0` at all times across all catalog items.
- 2. `reserved_budget <= available_budget` across all mandates.
- 3. `captured_amount <= authorized_amount`.
- 4. `revoked_mandate => 0` new financial authorizations.
- 5. `duplicate_intent_id => <= 1` order session.
- 6. `denied_action => 0` financial executions.

5. Chaos Resilience & Fail-Closed Safety (V3.7)

- Corrupted payloads, invalid cryptographic signatures, database lock errors, or upstream rail timeouts strictly fail closed with HTTP 400/401/403/409/502 without creating unauthorized financial effects.

V3 Release Gate Verification Record

- **Automated Tests:** 94 / 94 PASS (77 baseline + 10 V2 control plane + 7 V3 security infrastructure tests)
- **Live Adversarial Scenarios:** 19 / 19 PASS
- **Unauthorized Financial Paths:** 0 Observed
- **Audit Ledger Integrity:** 100% Cryptographically Verified
- **Build Status:** PASS